

# Activity Exemplar: Apply OS hardening techniques

## Section 1: Identify the network protocol involved in the incident

The network protocols involved in this incident are **Domain Name System (DNS)** and **Hypertext Transfer Protocol (HTTP)**.

The tcpdump traffic log shows that the browser first sent a DNS request to resolve the domain name **yummyrecipesforme.com** into its corresponding IP address. After receiving the correct IP address from the DNS server, the browser established an HTTP connection to retrieve the webpage.

Once the compromised webpage loaded, users were prompted to download an executable file. After executing the file, the browser initiated another DNS request for **greatrecipesforme.com**, received its IP address, and established another HTTP connection to the malicious website. This confirms that DNS was used for domain name resolution while HTTP was used to transfer the malicious content to the victim's browser.

## Section 2: Document the incident

Several customers reported that while visiting **yummyrecipesforme.com**, they were prompted to download a file claiming to provide free recipes. After executing the file, they were redirected to **greatrecipesforme.com**, and their computers began operating more slowly than normal. The website owner also reported being unable to log into the website's administrative account.

The cybersecurity team created a sandbox environment to safely investigate the issue. Using **tcpdump**, they monitored the network traffic while accessing the website. During testing, the browser successfully resolved the legitimate website through DNS before sending an HTTP request to load the webpage. Immediately afterward, the webpage prompted the download of an executable file. Once executed, the browser generated another DNS request for **greatrecipesforme.com**, followed by an HTTP request that redirected the browser to the malicious website.

Further investigation by the senior cybersecurity analyst revealed that unauthorized JavaScript had been inserted into the website's source code. The malicious script instructed visitors to download an executable file that redirected users to the fake website containing malware.

The investigation determined that the attacker initially compromised the administrative account through a **brute force attack**. The administrator password had never been changed from its default value, allowing the attacker to repeatedly guess the credentials successfully. After gaining access, the attacker modified the website's source code, changed the administrator password to lock out legitimate administrators, and embedded the malicious JavaScript responsible for redirecting website visitors.

### Section 3: Recommend one or more remediations for brute force attacks

One security control the organization should implement is **Multi-Factor Authentication (MFA)** for all administrator accounts.

MFA requires users to verify their identity using an additional authentication factor, such as a one-time passcode or authentication application, after entering their password. Even if an attacker successfully discovers an administrator password through a brute force attack, they would still be unable to access the account without the second authentication factor.

Additional security improvements include:

- Replacing all default passwords with strong, unique passwords.
- Limiting failed login attempts to prevent automated password guessing.
- Enforcing regular password changes.
- Monitoring authentication logs for suspicious login activity.
- Preventing the reuse of previous passwords.